
第 1 章 绪论

1、填空题

(1)信息安全包含系统安全、数据安全、内容安全和行为安全等四个层次。

(2)信息系统的脆弱性主要包括：电磁泄露、芯片脆弱性、操作系统安全漏洞、数据库系统安全漏洞、通信协议安全漏洞和移动存储介质安全漏洞。

(3)人为安全威胁的来源包括：物理攻击、网络攻击、恶意代码攻击和安全管理。

2、选择题（单选和多选）

(1)2008 年，XXX 国利用 BGP（Border Gateway Protocol 边界网关协议）劫持，破坏了格鲁吉亚的互联网，瘫痪了所有政府的基础设施。这种攻击行为属于（A）
A.网络攻击；B.物理攻击；C.病毒攻击；D.安全管理

(2)1982 年，由工业控制软件内嵌的病毒引发泛西伯利亚天然气管道发生大爆炸。这种攻击行为属于（C）
A.网络攻击；B.物理攻击；C.恶意代码攻击；D.安全管理

(3)以下描述是正确的有（C）
A.安全风险是“绝对的”，但我们可以完全消除；
B.信息系统的安全风险一定会使系统遭受安全损失；
C.安全风险虽不能完全消除，但可以降低对系统的危害；
D.安全威胁一定会造成安全损失，因此我们必须严防安全威胁。

3、问答题

(1)如果信息系统无任何脆弱性，是否就不存在安全风险呢？分析举例。
答题要点：(1)系统的安全问题根源；(2)脆弱性是系统存在安全问题的必要条件而非充分条件；(3)举例说明。

(2)信息系统的脆弱性和安全威胁分别体现在哪些方面？简要阐述。

答题要点：（1）系统脆弱性包含 6 个方面：电磁泄露、芯片脆弱性、操作系统脆弱性、数据库系统脆弱性、通信协议的安全漏洞和移动存储介质的安全漏洞；（2）安全威胁包括自然威胁和人为威胁，自然威胁如洪水、地震、设备老化等，而人为威胁包括：物理攻击、网络攻击、恶意代码攻击和安全管理。

（3）根据标准 GA/T 708-2007，信息系统的基本安全属性包含哪些？除此之外，你认为信息系统还需要有哪些安全需求？举例说明。

答题要点：（1）在标准 GA/T 708-2007 中，信息系统的基本安全属性包含：机密性、完整性和可用性。（2）如果设备放在无人值守的室外，需要增加物理安全需求；如果在社交媒体上发布照片等信息，需要增加隐私保护的需求，等等。（3）举例说明。

（4）如何理解：安全管理的最终目的是“使安全风险降低到用户和决策者都可以接受的程度”？

答题要点：（1）用户和决策者对安全风险的要求是不同的；（2）安全风险是绝对的，只能降低，不能消除；（3）安全管理的目的是降低安全风险，依据是系统安全评估要求所对应的标准，即降低安全风险以达到安全评估的要求。

第2章 信息系统安全体系结构（第一次作业及答案）

1、填空题

- (1) 在 ISO7498-2 标准中，安全体系结构框架包含协议层、安全服务和安全机制三个维度。
- (2) 安全体系结构的类型分为：抽象体系、通用体系、逻辑体系和特殊体系。
- (3) 密码算法的安全性依赖于：密钥的长度和破解密文的计算量。
- (4) 安全体系结构框架包含安全需求、安全策略、安全机制和安全模型等四个要素。

2、选择题（单选和多选）

- (1) 2000s-至今是安全体系结构的高级阶段，以下内容不是这一阶段强调的内容是（ C ）
- A.系统的保护、检测、反应和恢复；B.降低系统损失；C.严防死守；D.保障基本业务的连续性
- (2) 在 7 层 OSI 网络协议中，以下哪一层不能执行对等实体认证（ A ）
- A.物理层；B.网络层；C.传输层；D.应用层
- (3) 抽象体系结构设计主要应用于系统设计的以下哪个阶段（A）
- A.需求分析阶段；B.标准制定阶段；C.方案设计阶段；D.系统开发阶段
- (4) ISO7498-2 标准中的体系结构要解决信息生命周期中哪一阶段的安全问题（B）
- A.产生；B.传输；C.存储；D.使用；E.处理；F.销毁
- (5) 实现安全控制的极小化和隔离性应注意哪些事项（ BCD ）
- A.经济性原则；B.安全机制应尽量简洁、独立；C.数据隔离必须适度，不能极端；D.极小化系统功能模块的复杂度和规模尺度

3、问答题

- (1) 信息系统安全体系结构和信息系统体系结构安全之间的联系与区别？

答题要点：联系：都是针对信息系统的体系结构

区别：前者是整体设计，后者是后装设计

前者在体系结构设计时考虑安全问题，将安全机制和策略等用于信息系统；后者是系统设计完成后，评估其安全性，安全机制和策略等在系统设计之初不一定被考虑。

- (2) 信息系统安全体系结构设计对系统开发有什么好处？

答题要点：(1)从系统的角度考虑信息安全问题；(2)安全体系结构在安全需求、安全技术方法与安全评估标准、相关法律法规之间架起一座桥梁；(3)安全体系

结构能够极大地促进安全系统设计的重用；(4) 以一定的安全体系结构和信息系统安全标准作指导，有利于保障安全系统间的互连、互通、互操作，从而保证产品的安全性、兼容性和扩展性。

(3) 为什么应尽量考虑未来可能面临的安全需求很重要？

答题要点：如果未考虑可能面临的安全需求，后期增加的途径只有两条：要么改进系统原有的安全性；要么给系统增加新的安全属性。但前者，有时无法改进；后者，系统无法按照希望方式工作

(4) 什么是安全模型？

答题要点：安全模型用于准确描述系统在功能和结构上的安全特性，它反映了一定的安全策略。

第2章 信息系统安全体系结构（作业2答案）

1、填空题

（1）数据保密性可以分为连接保密性、无连接保密性、选择字段保密性、通信业务流保密性。

（2）IPSec 的两种工作模式分别为 传输模式 和 隧道模式。

（3）基于实体的安全体系结构中，安全属性包括：标识属性、认证属性、访问控制属性、保密及完整性属性。

（4）安全模型用于准确描述系统在 功能 和 结构 上的安全特性，它反映了一定的 安全策略。

2、选择题（单选和多选）

（1）在 7 层 OSI 网络协议中，以下哪一层不能执行数据来源认证（ B ）

A. 网络层；B. 物理层；C. 传输层；D. 应用层

（2）在 7 层 OSI 网络协议中，以下哪一层能够执行选择字段保密性（ E ）

A. 物理层；B. 数据链路层；C. 网络层；D. 传输层；E. 应用层

（3）基于实体的安全体系结构中，以下不属于其安全属性的是（ B ）

A. 标识属性；B. 资源属性；C. 认证属性；E. 访问控制属性；
F. 保密及完整性属性

（4）以下不属于认证属性的是（ C ）

A. 口令；B. 对称密钥；C. 加密；D. 公钥；E. 私钥

（5）实施最小特权时，采用的技术有（ ABD ）

A. 模块化编程；B. 结构化设计；C. 功能模块的耦合性小；
D. 面向资源的访问控制。

3、问答题

（1）为什么从系统设计之初就考虑安全性很重要？

答题要点：先建系统再考虑安全，势必造成代价巨大，才能够达到预期效果，原因是系统功能实现的方案很多，可能你选择的方案对于后期加入安全功能需要进行重大改造；后设计安全功能，很少能够获得满意的安全性。

（2）如何在系统设计时预设安全问题？

答题要点：预设安全问题不能太特殊或太具体；从抽象层次理解安全问题，而不是针对具体的问题；特别关注安全策略的制定。一旦改变，可能对系统造成灾难性的影响。

（3）入侵检测系统能否芯片化？为什么？

答题要点：（1）不行

原因：（1）入侵检测是非常个性化的应用，用户需求不同，入侵检测的规则就不同；（2）入侵检测的规则无法在芯片中实现，因为它会经常变化；（3）芯片化的功能必须具有通用性。

第3章 物理安全课后作业答案

一、 填空题

- 1、物理安全主要包括设备安全、环境安全和系统物理安全。
- 2、设备安全威胁主要是：设备的被盗与被毁、电磁干扰、电磁泄漏和声光泄漏。
- 3、系统物理安全涉及的技术要求包括：灾难备份与恢复，设备的资源、性能、状态和故障的管理，设备鉴别和访问控制，以及边界防护等。

二、 选择题

- 1、TEMPEST 技术的主要目的是（ A ）
A. 减少计算机中信息外泄 B. 保护计算机网络设备
C. 防盗和防毁 D. 保护计算机设备免受雷击和静电危害
- 2、以下哪一种不属于防电磁泄漏的措施（ D ）
A. 屏蔽 B. 使用低辐射设备 C. 滤波 D. 接地
- 3、不属于抗电磁干扰中的接地技术的是（ D ）
A. 保护接地 B. 系统接地 C. 屏蔽接地 D. 信号接地
- 4、防止计算机受到电磁干扰的主要措施有（ ACD ）
A. 屏蔽 B. 吸收辐射 C. 滤波 D. 接地
- 5、TEMPEST 研究内容包括（ ABCDEF ）
A. 研究信息处理设备的电磁泄漏机理；
B. 研究电磁泄漏的防护技术；
C. 研究各种屏蔽材料、屏蔽结构对电磁的屏蔽效果；
D. 研究有用电磁信息的提取技术
E. 研究电磁泄漏测试技术和标准；
F. TEMPEST 材料、元器件和设备的研制。

三、 问答题

- 1、物理安全涉及哪些方面的内容？

答题要点：1) 涉及设备安全、环境安全和系统物理安全；2) 给出三个方面的完

整定义；从保证整个信息系统安全的角度出发，说明这三个方面的安全需要考量的技术要求

2、电子信息设备所在机房的安全等级如何划分？

答题要点：应划分为 A、B、C 三级；划分时应当根据信息系统在国民经济与社会中的重要性进行讨论；对于每个等级，根据划分标准给出实例；对于不同安全等级的明确配置要求。

3、TEMPEST 技术中的低辐射技术是否能够通过保持安全距离实现的？

答题要点：不能；解释保持安全距离措施；对比低辐射技术并解释涉及内容

第4章 身份认证课后作业

一、填空题

- 1、公钥密码体制由明文，密文，公钥，私钥，加密算法，解密算法六部分组成。
- 2、对付重放攻击的方法有：序列号，时间戳，挑战/应答。
- 3、基于生理特征的身份认证技术中，生理特征必须具有如下特性：普遍性，唯一性，可测量性，稳定性，安全性。

二、选择题

- 1、下面关于公钥密码技术的说法正确的是：（ A ）
A. 公钥密码技术包括公钥和私钥； B. 公钥密码比对称密码更安全；
C. 公钥密码完全可以替代对称密码； D. 与对称密码相比，公钥密码实现密钥分配更加容易。
- 2、数字签名的特征不包括：（ D ）
A. 依赖性； B. 可保存； C. 抗伪造； D. 挑战/应答
- 3、下列关于数字签名的说法正确的是：（ C ）
A. 数字签名用于保证消息的私密性；
B. 数字签名的有效性不依赖于签名者的私钥安全性；
C. 数字签名可以保证消息的完整性；
D. 数字签名的有效性不依赖于签名者的公钥安全性。
- 4、下面关于公钥密码技术的说法错误的是：（ BCD ）
A. 公钥密码技术包括公钥和私钥； B. 公钥密码比对称密码更安全；
C. 公钥密码完全可以替代对称密码； D. 与对称密码相比，公钥密码实现密钥分配更加容易。

5、对称密码学可以实现的功能包括：（ ABD ）

A. 私密性； B. 完整性； C. 互易性； D. 消息认证

三、简答题

1. 请简述使用序列号抵抗重放攻击的基本思路，并说明其存在的问题。

答题要点：在每个用于认证的消息后附加一个序列号，只有序列号正确的消息才能被接收。但是这种方法存在一个问题，即它要求参与通信的每一方都必须记住其他通信各方最后附加的序列号。如果身份认证是一个不确定的过程，则通信一方要记住所有可能通信参与方的最后序列号，这是不可行的，特别是对于资源受限的实体更是如此，因此在身份认证过程中，一般不使用序列号。

2. 请简述对称密码算法作为身份认证的问题。

答题要点：对称加密算法是通信双方所持有，接收方通过验证发送方是否持有该密钥来验证发送方的身份，一旦出现纠纷，无法进行裁决，这是因为对称密钥无法唯一标识用户的身份。

3. 什么是单向认证协议？什么是双向认证协议？

答题要点：单向认证协议的接收方通过验证发送方或仲裁者的签名结果，来验证发送者的身份。双向认证协议又称为相互认证协议，可以使通信双方在确认对方身份的基础上交换会话密钥。

第五章 访问控制课后作业（1）

一、填空题

- 1、访问控制是对主体访问客体的能力或权力的限制，它包括：主体、客体、引用监控器和访问控制策略四个要素。
- 2、基于所有权的访问控制分为：自主访问控制和强制访问控制。
- 3、访问控制的二元组描述方法通常包含访问控制矩阵、访问控制表、访问能力表和授权关系表四种形式。

二、选择题

- 1、访问控制是指确定（ A ）以及实施访问权限的过程。
A. 用户权限； B. 可给予哪些主体访问权利；
C. 可被用户访问的资源； D. 系统是否遭受入侵
- 2、以下对访问控制列表和访问能力表说法正确的是（ D ）
A.访问能力表表示每个客体可以被访问的主体及其权限；
B.访问控制列表说明了每个主体可以访问的客体及其权限；
C.访问控制列表一般随主体一起保存；
D.访问能力表更容易实现访问权限的传递，但回收访问权限较困难。
- 3、下图为访问控制列表。以下说法正确的是（ D ）

主体	客体			
	File1	File2	File3	File4
N1	Own,R,W,E		Own,R,W,E	
N2	R	Own,R,W,E	W	R
N3	R,W	R		Own,R,W,E

- A.N1 是管理员； B.N2 是管理员； C.N3 是管理员； D.都不是管理员
- 4、（多选）下列关于访问控制主体和客体的说法中，错误的是（ BD ）
A.主体是一个主动的实体，它提供对客体中的对象或数据的访问要求；
B.主体可以是访问信息的用户、程序和进程；
C.客体是含有被访问信息的被动实体；
D.一个对象或数据如果是主体，则其不可能是客体

5、(多选)访问控制策略的制定必须体现主体、客体和访问规则集等三者之间的关系,需要遵循以下原则(BCD)

A.保密性原则; B. 最小特权原则; C.最小泄漏原则; D.多级安全原则

三、简答题

1、学校教务系统中,学生只有提交了评教,才能看到分数,这是“访问控制”吗?为什么?

答题要点:(1)是。(2)解释什么是访问控制;(3)这是访问控制策略,给出了主体访问客体的约束。

2、名称解释:自主访问控制,强制访问控制。

答题要点:自主访问控制是指资源的所有者不仅拥有该资源的全部访问权限,而且能够自主的将访问权限授予其他的主体,或从授予权限的主体收回其访问权限。

强制访问控制,它不再让普通用户管理资源的授权,即使是资源的创建者也不行,而将资源的授权权限全部收归系统,由系统对所有资源进行统一的强制性控制,按照事先制定的规则决定主体对资源的访问权限,即使是创建者用户,在创建一个资源后,也可能无权访问该资源。

3、访问控制策略制定遵循的基本原则是什么?举例说明。

答题要点:(1)遵循最小特权、最小泄漏、多级安全原则。(2)举例的要求:最小特权应强调权限的最小划分,以保证对主体权力最大限度的限制,同时又不影响主体的功能实现;最小信息泄漏需要说明只有必要的信息被主体知道,是在主体确定做某件事之前把信息分配给主体;多级安全原则强调安全等级的划分,并基于安全等级限制信息的流动。

第五章 访问控制课后作业（2）

一、填空题

- 1、基于角色的访问控制模型族中包括 RBAC0、RBAC1、RBAC2 和 RBAC3 四个模型
- 2、基于属性的访问控制模型以 属性 为最小的授权单位，替代基于角色的访问控制模型中以 身份标识（或角色） 为依据的授权方式。
- 3、访问控制实现的类别包括：接入访问控制、资源访问控制 和 网络端口和节点访问控制。

二、选择题

- 1、以下哪组都是完整性模型（ B ）
 - A.BLP 模型和 BIBA 模型；
 - B.BIBA 模型和 Clark-Wilson 模型；
 - C.Chinese-wall 模型和 BLP 模型；
 - D.Clark-Wilson 模型和 BLP 模型
- 2、BLP 访问控制模型的读写原则是（ A ）
 - A.向下读，向上写；
 - B.向上读，向上写；
 - C.向下读，向下写；
 - D.向上读，向下写
- 3、安全系统在实现引用验证机制时必须同时满足以下哪些原则（ ACDE ）
 - A. 必须具有自我保护能力；
 - B. 尽可能处于活跃状态，从而保证程序对资源的引用最大限度地得到引用验证机制的仲裁；
 - C. 防篡改，保持自身的完整性；
 - D. 不可绕过性；
 - E. 必须设计得足够小，以利于分析和测试，从而能够证明它的实现是正确的和符合要求的。
- 4、有关访问控制列表（ACL）描述不正确的是（ BCD ）
 - A.表述直观，比较容易查出对某一特定资源拥有访问权限的所有用户；
 - B.单纯使用 ACL 可以实现复杂的安全政策；
 - C.单纯使用 ACL 可以实现最小权限原则；
 - D.对于较大规模的信息系统实现整个组织范围内一致的控制政策比较方便
- 5、关于访问控制列表和访问能力表的描述正确的是（ ABC ）
 - A. 对于客体访问权限浏览，访问控制表比访问能力表容易；
 - B. 访问控制能力表比访问控制列表容易实现访问权限传递；

C. 访问控制列表比访问能力表更容易实现访问权限回收；

D. 访问控制列表转换到访问能力表比较难，反之则相对容易

三、简答题

1、解释名词：基于属性的访问控制。

答题要点：基于属性的访问控制（ABAC）是通过对实体属性添加约束策略的方式实现主、客体之间的授权访问。ABAC 模型以属性为最小的授权单位，替代基于角色的访问控制模型中以身份标识为依据的授权方式，以满足开放网络环境下资源访问控制的要求。

2、BLP 模型和 Biba 模型的安全策略和安全访问规则？分析它们的适用范围和可能存在的问题。

答题要点：

（1）BLP 模型采用多级安全的策略，访问规则包括强制安全访问规则和自主安全访问规则。

（2）Biba 模型采用多级安全原则和最小泄漏原则。采用了五种非自主安全访问规则和基于 ACL、客体层次结构、环的自主安全访问原则。

（3）BLP 模型中信息单向不可逆，客体具备高度机密，但是会带来隐藏通道问题。不能阻止未授权主体修改客体。

（4）Biba 是完整性模型，能够与 BLP 模型结合。但是完整性级别标签确定困难、目的性不明确、与 BLP 结合困难。

3、如何理解“角色互斥”和“角色继承”？

答题要点：

（1）静态角色互斥是用户的不同角色之间不冲突；动态角色互斥是在会话选择时，角色与主体任意一个角色都不冲突。

（2）角色继承表明了角色的组织关系，体现了访问权限的继承。